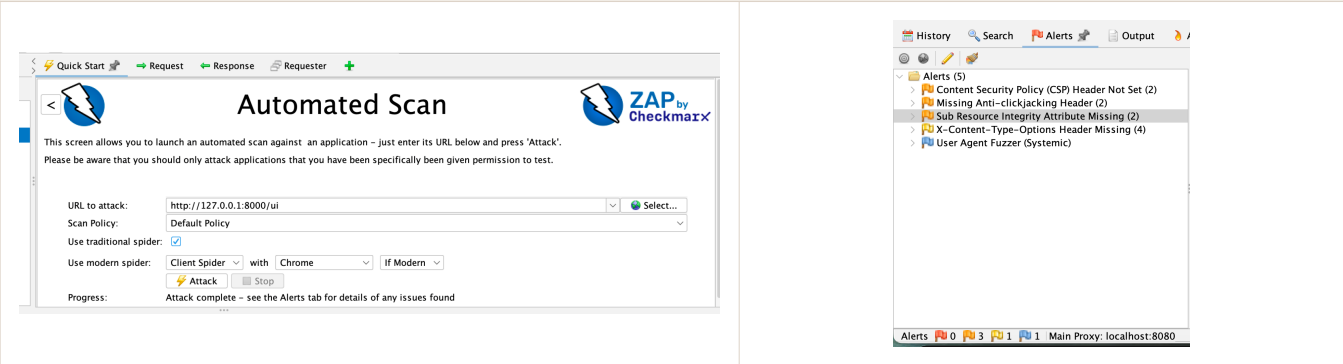


Basic Vulnerability Assessment

OWASP ZAP testing of the DeRexi local web interface

TARGET	METHOD	RESULT
http://127.0.0.1:8000/ui	OWASP ZAP automated scan Default Policy	5 alert categories 3 medium / 1 low / 1 informational



Evidence 01 - ZAP completed an automated scan against DeRexi's local /ui route. The Alerts view recorded CSP, anti-clickjacking, Subresource Integrity, X-Content-Type-Options, and User-Agent findings.

PRIMARY FINDINGS

01

CONTENT SECURITY POLICY HEADER NOT SET

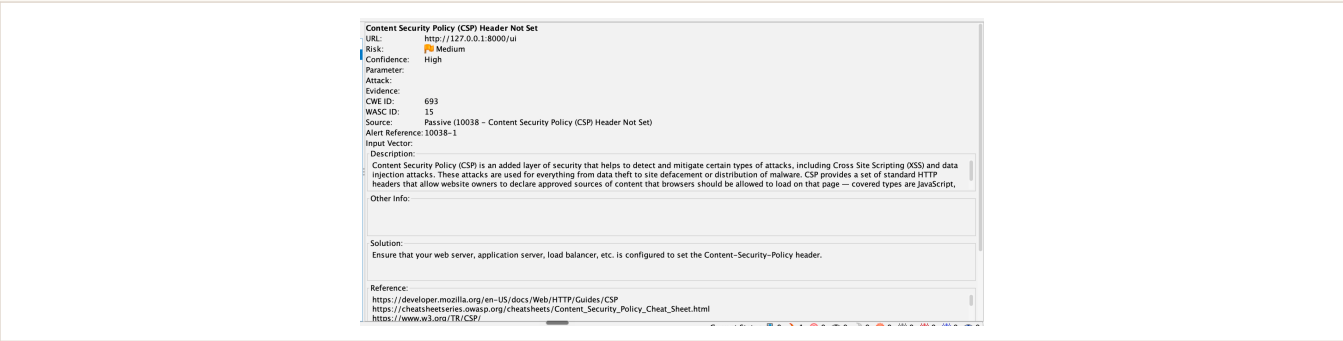
Observed: ZAP reports that DeRexi does not send a Content-Security-Policy header on the tested UI response. The scanner identifies this as a missing browser-side security control.

Security relevance: A CSP restricts which content sources a browser may load. Its absence removes a defense-in-depth control that can help limit the impact of injected or untrusted content.

Reproduce: 1) Start DeRexi locally. 2) Open ZAP Automated Scan. 3) Target **http://127.0.0.1:8000/ui**. 4) Run the default scan. 5) Open Alerts > Content Security Policy (CSP) Header Not Set.

Recommended remediation: Configure the application/server to return a deliberate Content-Security-Policy header and test the policy against DeRexi's actual scripts, styles, fonts, and API behavior before enforcing it.

MEDIUM / HIGH
CONFIDENCE



Two reproducible web-security findings satisfy the core assessment requirement; additional ZAP observations are retained as supporting evidence.

**MEDIUM / MEDIUM
CONFIDENCE**

Recommended remediation: Add an appropriate framing policy - preferably CSP **frame-ancestors**, or X-Frame-Options where needed - and verify that legitimate DeRexi pages do not require third-party framing.

OWASP TOP 10 ALIGNMENT

The current OWASP Top 10 identifies missing or insecure security headers/directives as an example of security misconfiguration. Both primary findings concern absent browser security headers on DeRexi's web response.

```
X-Content-Type-Options Header Missing
URL http://192.0.0.1:8000/ [2] Low
Confidence Medium
Parameter x-content-type-options
Value text/html
CWE ID 603
WASC ID 15
Passive (SSD12 - X-Content-Type-Options Header Missing)
Input Vector
Description
The Anti-MIME-Spoofing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME sniffing, which may allow an attacker to bypass the declared content type and download content that was not intended to be downloaded.
Current state 2014-04 legacy versions of Firefox will use the declared content type if it is, or is less, than performing MIME sniffing.
Other info
This still applies to error pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browser sniffing to occur from their actual content.
As "No" checked this rule will not alert on client or server error responses.
Solution
Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to "nosniff" for all web pages.
If possible, ensure that the end user sets a standards-compliant and modern web browser that does not support MIME-sniffing at all, but that can be directed by Reference
https://msdn.microsoft.com/en-us/windows/ie/desktop/explorer_ie-developer/compatibility/ie7294131 vs 851
https://owasp.org/www-project/Security_Headers
```

ZAP reports that **nosniff** is not set. Recommended hardening is to return the correct Content-Type and set X-Content-Type-Options: nosniff.

Requirement satisfied: DeRexi was tested with OWASP ZAP against a self-created local application. The assessment documents at least two reproducible web-security findings, records scanner evidence, explains their security impact, and provides remediation recommendations. No remediation is claimed as completed in this report; these findings become actionable hardening work for the next DeRexi security pass.